

PwC Simulation Deliverable for Task 1: Risk Assessment

Hi Senior Associate,

I completed my review of MedTech Industries' Procure-to-Pay Standard Operating Procedure and compared the documented process against common internal control and ITGC practices.

I identified several potential business process gaps, including automatic approval of purchase requisitions without managerial review, a lack of documented Purchase Order approval, limited invoice validation procedures that do not mention a three-way match, and segregation of duties concerns where purchasing coordinators can process requisitions, obtain vendor quotes, write checks, and sign checks. These gaps increase the risk of unauthorized purchases, fraudulent payments, and financial reporting errors.

From a systems perspective, I identified several access control concerns. The SOP states that shared credentials are used to access the General Ledger system, user access requests are granted via email, and privileged access may be approved verbally over the phone. Additionally, the document does not describe periodic access reviews, formal de-provisioning procedures, password requirements, or audit logging. These weaknesses could increase the risk of unauthorized system access and reduce accountability.

After reviewing the documentation, I have a few follow-up questions:

- Is manager approval required before purchase requisitions are processed?
- Is there a formal Purchase Order approval workflow before orders are sent to vendors?
- Is a three-way match performed between the Purchase Order, Goods Receipt, and Invoice?
- Why are shared General Ledger credentials being used instead of individual user accounts?
- Are periodic user access reviews and timely de-provisioning performed?
- Are privileged access requests documented and approved in writing?
- Are dual signatures required for payments above a defined threshold?

Based on the documentation provided, these areas appear to present opportunities to strengthen the company's internal control environment in preparation for SOX compliance.

Thanks,

April Radcliff